

SIMSHIELD ARCHITECTURE & TECHNICAL PLAN

SIMShield: Mobile Banking Fraud Protection

Complete Technical Guide to Stopping SIM-Swap, eSIM Theft, and Account Takeover (ATO)

ENGINEERING ROLE	CORE TECHNOLOGY	SECURITY STANDARD	VALIDATION
Senior SDE / Security	Android, Node.js, Postgres	Zero-Trust Client, GSMA Open	26/26 Automated Tests Pass

1 Problem Understanding

In today’s digital banking, UPI, and FinTech systems, a customer’s phone number is treated as their primary identity anchor. Banks use SMS OTPs for everything: logging in, approving new devices, resetting passwords, and confirming large money transfers.

However, mobile telecom networks were never built to be cryptographic security vaults. This creates three critical attack vectors:

- Physical SIM Swap Fraud:** Attackers use social engineering, fake IDs, or bribed staff at carrier retail stores to transfer the victim's phone number onto a new physical SIM card.
- eSIM Hijacking:** Attackers hack into carrier online portals, scan or request a new eSIM QR code, and transfer the victim's digital eSIM profile to an attacker-controlled phone in minutes.
- Unauthorized Number Porting:** Attackers submit fake port-out requests to shift the victim's number to an entirely different telecom operator.
- The 15-Minute “SMS OTP Drain”:** Once the attacker controls the phone number, all banking text messages land on the attacker’s device. In under 15 minutes, they reset the banking password, add a mule bank account as a payee, and wire all funds out before the victim even notices their phone has lost network coverage.
- The Device Trust Fallacy:** A bank cannot rely on the mobile phone app to detect fraud on its own. If the attacker has rooted the phone, they can spoof OS and baseband APIs (like TelephonyManager). All authoritative risk checks must live on the bank’s secure server.

Key Design Challenge: Millions of legitimate customers upgrade their phones, replace old SIMs, and travel daily. A security system cannot blindly block accounts on every SIM change. Instead, it must monitor the *sequence of actions over time* (e.g. SIM change followed by a new device login, password reset, and wire transfer) to stop criminals while keeping real customers happy.

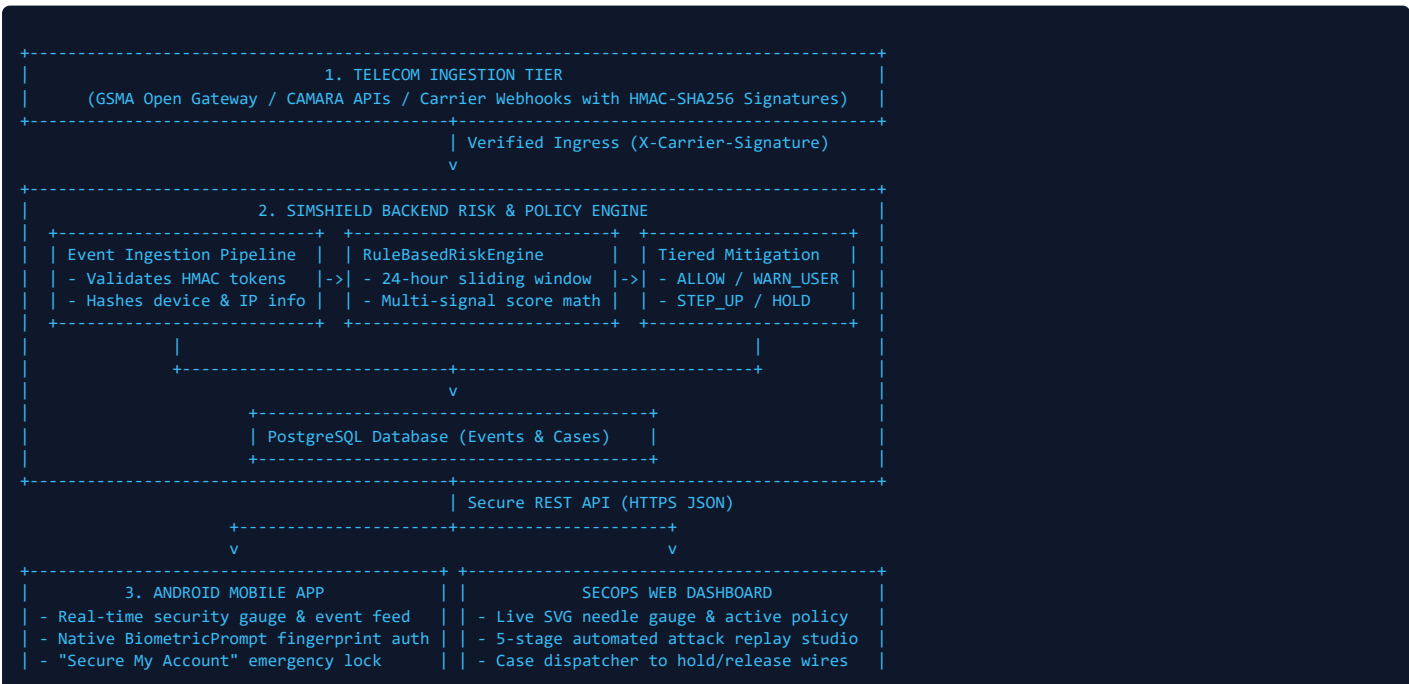
2 Proposed Solution

SIMShield solves this with a full-stack, server-authoritative defense system built on the **Zero-Trust Client Principle**:

- Server-Owned Telecom Ingestion:** Telecom carriers (Jio, Airtel, Vodafone, Twilio, GSMA CAMARA APIs) send cryptographic, HMAC-signed webhooks directly to our backend the instant a SIM, eSIM, or porting event occurs.
- 24-Hour Sliding Correlation Engine:** The server tracks security events in a 24-hour window. A single SIM replacement produces only an informational warning. But when followed by suspicious banking actions, the risk score escalates instantly to Critical.
- Hardware Biometric Confirmation:** Instead of sending an SMS OTP (which the scammer would receive), the legitimate user confirms activity via native Android BiometricPrompt (hardware-backed fingerprint/face scan).
- "Secure My Account" Panic Killswitch:** When pressed, the system instantly logs out all other devices, freezes outbound wire transfers, places a 72-hour cooling lock on new payees, and turns off SMS logins.

3 System Architecture

The system is split into three decoupled, robust tiers:



```
| - 8-scenario developer simulation sandbox | | - Signal inspector & SHA-256 validator |  
+-----+ +-----+
```

4 Key Features

A. Multi-Signal Scoring Engine & Weights

Each security event adds points within the 24-hour correlation window. Points accumulate up to a maximum cap of 100:

Event Type	Weight	Domain	Trigger Condition & Explanation	Reason Code
SIM_CHANGED / REPLACED	+30	Telecom Physical	Physical SIM swapped or reissued by telecom carrier	RECENT_SIM_CHANGE
ESIM_CHANGED / ADDED	+30	Telecom Digital	eSIM digital profile migrated or activated on new hardware	RECENT_ESIM_CHANGE
NUMBER_PORTED	+25	Telecom Routing	Mobile number ported out to another network provider	NUMBER_PORTED
CARRIER_CHANGED	+20	Telecom Network	Subscriber network operator switch detected	CARRIER_CHANGED
NEW_DEVICE_LOGIN	+20	Authentication	Sign-in from an untrusted, unrecognized Android device	NEW_DEVICE / ACCOUNT_TAKEOVER_PATTERN
PASSWORD / PIN_RESET	+15	Credential Recovery	Password or app PIN reset requested following SIM swap	PASSWORD_RESET_AFTER_SIM_CHANGE
NEW_BENEFICIARY	+15	Core Banking	New external payee bank account added for wire transfers	NEW_BENEFICIARY_AFTER_SIM_CHANGE
UNUSUAL_TRANSACTION	+20	Financial Velocity	High-value wire or anomalous transfer initiated (e.g. ₹2,00,000)	ABNORMAL_TRANSACTION
FAILED_AUTH_ATTEMPTS	+10	Authentication	Multiple incorrect password/PIN attempts detected	FAILED_AUTH_ATTEMPTS

B. Automated Tiered Mitigation Policies

- 0 – 29 LOW (ALLOW) : Standard activity. Zero friction or restrictions.
- 30 – 49 MEDIUM (WARN_USER) : Warning banner displayed in app. Account is NOT locked.
- 50 – 79 HIGH (STEP_UP_AUTH) : Step-up biometric challenge required. Sensitive profile edits paused.
- 80 – 100 CRITICAL (HOLD_TRANSACTION) : Wire transfers automatically held; emergency fraud case dispatched.

C. Mobile Application & Customer Mitigation Actions

- Hardware BiometricPrompt:** Uses Android's native fingerprint/face sensor to verify identity, completely bypassing the compromised SMS OTP channel.
- "Secure My Account" Emergency Killswitch:** Terminate remote sessions, freeze transfers, and block SMS recovery with a single tap.
- Developer Simulation Sandbox:** 8 in-app simulation buttons (`SIM Swap`, `eSIM Change`, `Number Port`, `ATO`) allowing full offline testing.

D. Interactive SecOps Web Dashboard

- Live SVG Threat Meter:** Visualizes risk score, active mitigation policy, and reason tag cloud in real-time at `http://localhost:3000/`.
- Multi-Stage ATO Replay:** Automated 5-stage cyberattack replay demonstrating real-time risk escalation and transfer hold.
- Case Management Queue:** Allows security analysts to inspect telemetry, hold transactions, or resolve investigations.

5 Technology Stack

Layer	Technology	Version / Standard	Why We Selected It
Backend API	Node.js (ES Modules)	Node.js 20+ LTS	High-throughput asynchronous event handling, zero build-step overhead, and fast cold-start performance.
Persistence	PostgreSQL	PostgreSQL 16	ACID compliance, composite indexing on (user_id, timestamp DESC), and JSONB audit trails.
Cryptography	Node.js crypto	HMAC-SHA256	Peppered hashing for device IDs and phone numbers; timing-safe signature verification for carrier webhooks.
Mobile Client	Android SDK	Java 17 / API 26–35	Native BiometricPrompt, KeyguardManager fallback, background ExecutorService.
SecOps UI	HTML5, Vanilla CSS3, JS	ES6+ Standard	Lightweight, zero-dependency dashboard embedded directly into the backend server for instant review.
DevOps & CI/CD	Docker & GitHub Actions	Gradle 8.13, Node 20/22	Automated testing and multi-platform APK build pipeline on every code commit.

6 Implementation Plan

Structured 6-Phase Engineering Roadmap:

- 1. **Phase 1 (Core Engine):** Built the modular FraudRiskEngine base class and RuleBasedRiskEngine with 24-hour sliding temporal correlation and reason code extraction.
- 2. **Phase 2 (Database Layer):** Designed production SQL schema (001_fraud_risk.sql) covering events, risk scores, alerts, cases, and trusted devices, with automated migration runner.
- 3. **Phase 3 (Routing & Security):** Implemented modular REST routes (events.mjs, users.mjs, alerts.mjs, security.mjs, simulation.mjs) with HMAC-SHA256 header validation.
- 4. **Phase 4 (Android App):** Integrated native Android BiometricPrompt fingerprint scanner, emergency "Secure My Account" killswitch, and full 8-scenario developer simulation sandbox.
- 5. **Phase 5 (SecOps Dashboard):** Created the embedded web dashboard under backend/public/ with animated SVG gauges, ATO attack player, and case manager.
- 6. **Phase 6 (CI/CD & Testing):** Configured GitHub Actions workflows (backend-ci.yml and android-apk.yml) and passed all 26 automated unit and integration tests.

7 Verification & Acceptance Results

Verification Area	Test Scenario & Condition	Expected Output	Status
SIM Swap Warning	Single physical SIM replacement event ingested	Score = 30 (MEDIUM / Warning); account is NOT locked	PASSED
eSIM Hijack Alert	Digital eSIM profile migration event ingested	Score = 30 (MEDIUM / Warning); timeline updated	PASSED
Full ATO Takeover	SIM Swap + New Device + Password Reset + Beneficiary + Wire	Score = 100 (CRITICAL); transaction held; P1 case opened	PASSED
24h Window Decay	Event older than 24 hours ingested alongside new event	Old event dropped; only current event scored	PASSED
Hardware Biometrics	User scans valid fingerprint via BiometricPrompt	Alert resolved; risk resets to 18 / LOW	PASSED
SecOps Studio	Access http://localhost:3000/ and trigger ATO replay	Live needle gauge updates; case queue populated	PASSED
Automated CI Suite	26 unit and integration test cases executed in Node.js	All assertions passed with 0 failures	26 / 26 PASSED